从数据量到信息噪声：配置复杂性与工具孤岛化是 SOC 信噪比下降的主要原因

Innocent Twagirumukiza • 2026年10月

摘要

多年来，安全运营中心（SOC）面临着一个越来越难以忽视的悖论：组织部署的检测工具越多，告警数量就越多，分析人员也就越难分辨真正重要的信息。这种现象，即“告警疲劳”（alert fatigue），常被归咎于数据过多。然而，仔细研读文献和最新调查（2025–2026年）后可以发现，数据量只是次要因素。真正导致信噪比下降的，是工具的配置方式，以及这些工具彼此孤立的程度。本文提出一个用于区分这些影响的分析框架，并得出若干实践启示。

关键词：安全运营中心，告警疲劳，信噪比，工具泛滥（tool sprawl），配置复杂性，基于风险的告警（risk-based alerting）。

1. 引言

十五年前，一个 SOC 往往只需要一套 SIEM、几个探针，以及一支整天筛查日志的分析团队。如今，大多数组织拥有层层叠加的工具（EDR 或 XDR、威胁情报平台、GRC 方案、攻击面管理模块、云工具，有时还有 SOAR），每种工具都产生各自的告警流。数据说明了问题。微软/Omdia 2026年报告指出，46% 的告警是误报，42% 的告警从未被查看。同年的 SANS SOC 调查显示，三分之二的团队表示已跟不上节奏。Filigran 在《威胁管理现状》中指出，近一半的 SOC 专家认为其工具之间协作不佳。

面对这些发现，一种解释反复出现：数据太多。这种想法很直观，但经不起推敲。在其他处理海量信息的领域（量化金融、医学影像、物流），数据量的增加，只要伴随着细致的整合和恰当的配置，通常会提高决策质量。为什么网络安全就应该是例外呢？

我在此主张的论点更为明确：困扰当代 SOC 的噪声，并非主要源于数据量，而是源于工具配置的复杂性及其孤岛化。换言之，制造噪声的与其说是数据本身，不如说是数据被产生、被配置和被隔离的方式。

2. 文献怎么说

告警疲劳并非新概念。早在2010年代中期，就有多项研究描述了分析人员在面对几乎持续不断的低相关度告警时逐渐麻木的现象。较新的调查只是进一步证实了问题的严重性。SANS、ISC2 及合作伙伴的一项联合研究（2025年）已经指出，66% 的 SOC 团队无法再消化告警量，90% 的团队积压了大量待处理事项。同一批数据还显示，每天近 44% 的告警从未被调查，超过 70% 的分析人员报告出现倦怠症状。尽管在自动化方面投入巨大，这些数字此后几乎没有改变。

信噪比仍然是描述这一状况最有用的指标。信号是指真正与威胁或事件相关的事件。噪声则包括误报、重复告警、缺乏上下文的告警，以及更广泛意义上一切耗费分析人员时间却不提供可操作信息的内容。多项文献综述，尤其是 Ndichu 等人2026年发表的综述，表明该比率在2018年至2026年间持续恶化。

工具泛滥（tool sprawl）解释了这种恶化的一部分原因。如今，普通企业管理着十一到十八种检测与响应工具，有时更多。每种方案都带来自己的检测逻辑、阈值、分类体系，往往还有自己的界面。同一种可疑行为（暴力破解尝试、横向移动、身份异常），因此可能产生多条互不相通的告警。分析人员不得不手工重建本可以在上游完成关联的事件链。微软/Omdia 与 Vectra 2026年的研究证实，碎片化程度最高的组织，也是不处理告警最多的组织。

检测规则的配置所起的作用至少同样重要。大多数工具出厂时带有“开箱即用”的配置，其设计目的是尽量减少漏报。代价是长期居高不下的误报率。Fraunhofer FKIE 关于基于风险的告警的研究相当清楚地表明，仅凭工具自身声明的严重程度来预测并不可靠（平均 AUROC 约为 0.72）。相反，综合多个维度的风险评分（同一资产上的告警数量、告警类型的多样性、业务关键程度），表现要好得多（平均 AUROC 为 0.92）。这表明，如何给告警赋予价值，比告警的数量本身更重要。

近年来提出的解决方案（基于风险的告警、XDR 平台、SOAR、基于人工智能的智能体方法、持续威胁暴露管理），大多针对告警的下游处理。它们帮助更快地分流，或事后进行关联。它们很少处理上游的复杂性，即工具如何配置以及彼此如何连接。而这恰恰是文献中尚未充分探讨的问题。

3. 一个简明的分析框架

可以区分出导致 SOC 噪声的三个因素：

- 所产生的数据量；
- 配置复杂性（规则数量、阈值与分类体系的异质性、缺乏对业务背景的适配）；
- 孤岛化程度（工具之间缺乏集成和原生关联）。

数据量主要起放大器的作用。高数据量如果配合细致的配置和良好的集成，完全可以产生可接受的信噪比。反之，即使数据量适中，一旦工具配置不当且彼此孤立，也会迅速变得嘈杂。可以这样概括：有效噪声取决于数据量与（配置复杂性加孤岛化程度）之和的乘积。

这个模型的优点是简单。它有助于理解为什么有些组织尽管面对大量数据，表现却优于其他组织：它们把投入放在检测工程和集成上，而不是不断增加新的告警来源。

4. 近期数据显示了什么

2025年和2026年的调查在几个方面趋于一致。告警数量确实增加了，在大规模采用人工智能工具的环境中，一年内有时增长超过 50%。但抱怨告警疲劳最多的组织，同时也是报告未集成工具数量最多、情境化配置水平最低的组织。基于风险的告警研究表明，即使数据量不变，更好的优先级排序也能显著减轻误报负担。最后，精简了技术栈或认真投入检测工程的企业，其信噪比的改善比那些只是在下游增加处理能力的企业更为明显。

换句话说，数据量放大了配置不当和严重孤岛化所带来的影响，但它并不是首要原因。

5. 讨论

“数据太多会产生噪声”这一观点的优点是简单。它的缺点是转移了人们对真正可操作杠杆的注意力。产生噪声的，首先是三个具体机制。

第一是重复。同一技术事件在多个工具中触发各自独立的告警。分析人员随后必须手工重建本可在上游完成关联的事件链。第二是上下文丢失。一条技术上正确的告警，如果没有资产背景、用户历史或威胁情报信息的补充，其价值就会大打折扣。孤岛化恰恰阻碍了这种补充。第三个机制涉及阈值和规则。默认配置以较高的误报率为代价优先保证检出。如果没有持续的检测工程工作，这种权衡会随着时间推移而恶化。

以下游分流为中心的纯技术方案（更多的人工智能、更多的处置手册），可以在短期内减轻团队负担，但它们没有解决根本原因。要持久地降低噪声，就必须作用于模型中的两个乘性因素：配置复杂性和孤岛化程度。基于风险的告警和持续威胁暴露管理方法正朝这个方向努力，前提是实施得当。同时也需要保持警惕：某些校准不当的生成式人工智能方案，可能因产生缺乏上下文或难以解释的告警，而自身成为新的噪声来源。

6. 若干启示

对运营团队和 CISO 而言，可以得出若干思路。定期按工具和用例衡量信噪比是有益的，而不是只满足于告警总量。在增加新工具之前，往往更应该先精简现有工具。对情境化检测工程的投入，通常比增加分流能力回报更大。基于风险的告警和持续威胁暴露管理方法值得探索，前提是拥有高质量的输入数据。

在研究方面，仍有工作要做。目前仍缺乏超越简单误报率的“有效噪声”标准化指标。能够衡量工具精简和配置改进实际影响的纵向研究将特别有价值。最后，智能体方案必须在真实的运营条件下评估，而不仅仅是在公开数据集上评估。

7. 结论

困扰当代 SOC 的噪声并非数据量带来的宿命。它首先源于配置的复杂性和工具的孤岛化。通过把精力重新集中在集成、检测工程和基于风险的优先级排序上，可以在不放弃检测覆盖面的前提下改善信噪比。这一澄清促使我们超越略显简单的“数据太多”假设，转而关注把遥测数据变成噪声的具体机制。

参考文献

- Crowley, C., et al. (2026). 2026 SANS SOC Survey Insights: A Decade of Evolution in Cyber Defense. SANS Institute. https://www.sans.org/white-papers/2026-sans-soc-survey-insights-decade-evolution-cyber-defense

- Filigran. (2026). State of Threat Management Report. Filigran. https://filigran.io/resources/state-of-threat-management
- Microsoft & Omdia. (2026). State of the SOC 2026. Microsoft.
- Ndichu, S., Ban, T., Ozawa, S., Takahashi, T., & Inoue, D. (2026). AI-Driven Security Alert Screening and Alert Fatigue Mitigation in Sec urity Operations Centers: A Survey. arXiv preprint arXiv:2605.08316.
- Uetz, R., Bönninghausen, P., Hackländer-Jansen, L., & Henze, M. (2026). Can Risk-Based Alerting Mitigate Cybersecurity Alert Fatigue ? arXiv preprint arXiv:2609.02465.

© Innocent Twagirumukiza